

ItsyBitsy

Put your ELK knowledge together and investigate an incident.

Task 1 – Introduction

In this challenge room, we will take a simple challenge to investigate an alert by IDS regarding a potential C2 communication.

Task 2 – Scenario – Investigate a potential C2 communication alert

Scenario

During normal SOC monitoring, Analyst **John** observed an alert on an IDS solution indicating a potential C2 communication from a user **Browne** from the HR department. A suspicious file was accessed containing a malicious pattern :{ _____ }. A week-long HTTP connection logs have been pulled to investigate. Due to limited resources, only the connection logs could be pulled out and are ingested into the connection_logs index in Kibana.

Our task in this room will be to examine the network connection logs of this user, find the link and the content of the file, and answer the questions.

Answer the questions below

How many events were returned for the month of March 2022?



Figure 1: Kibana Discover showing 1,482 events for March 2022

I set the time range to cover March 2022 in Kibana Discover and reviewed the total number of returned events. Kibana showed 1,482 hits for the selected month.

Answer: 1482

What is the IP associated with the suspected user in the logs?

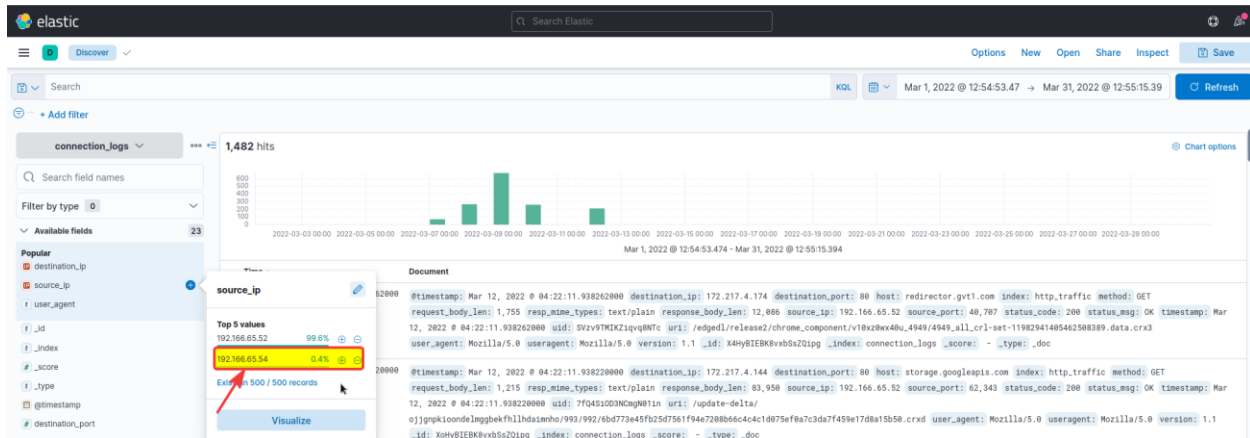


Figure 2: Reviewing the source_ip field values in Kibana Discover

I reviewed the source_ip field to see which IP addresses appeared in the March 2022 connection logs. Most of the traffic came from 192.166.65.52, but 192.166.65.54 stood out because it appeared as a much smaller and unusual source.

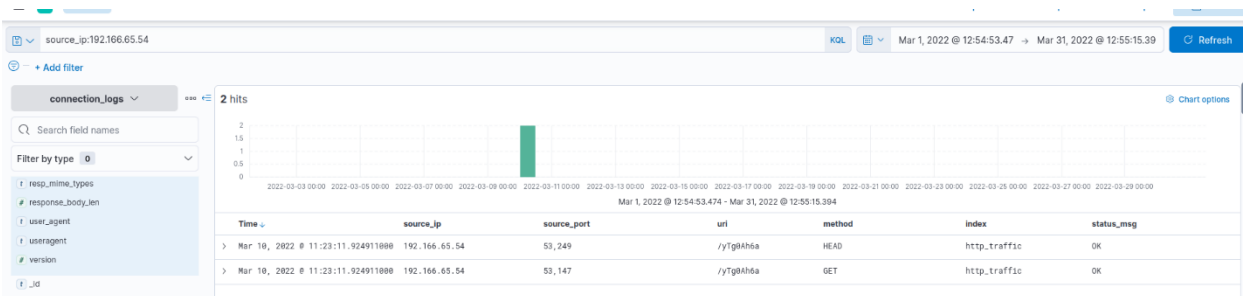


Figure 3: Filtering the logs for the suspected source IP

I then filtered the logs for source_ip:192.166.65.54 to review its activity more closely. The filtered results showed two events from this IP, which helped confirm it as the suspected user IP.

Answer: 192.166.65.54

The user's machine used a legit windows binary to download a file from the C2 server. What is the name of the binary?

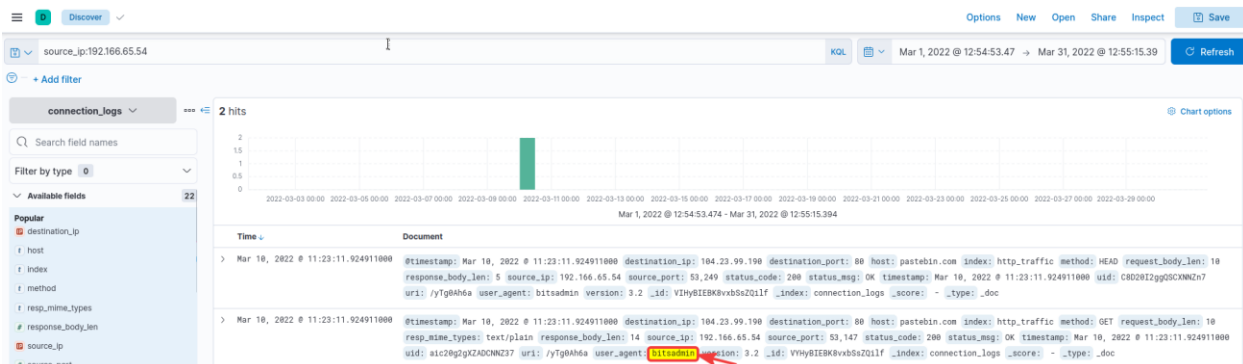


Figure 4: Filtering the suspected IP and identifying the Windows binary

After filtering the logs for the suspected IP address 192.166.65.54, I reviewed the two returned HTTP events. Both events showed the user_agent value as bitsadmin, which indicates that the Windows bitsadmin.exe binary was used to download a file from the remote server.

“bitsadmin.exe is a legitimate Windows tool used to transfer files in the background. Attackers can abuse it to download malicious files from a remote server.”

Answer: bitsadmin.exe

The infected machine connected with a famous filesharing site in this period, which also acts as a C2 server used by the malware authors to communicate. What is the name of the filesharing site?

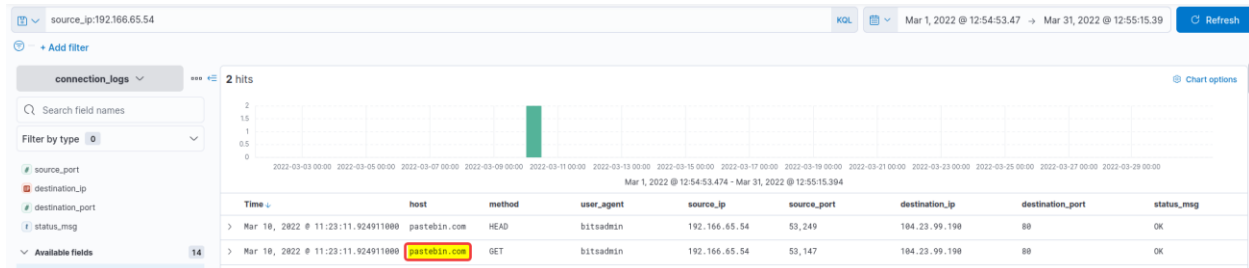


Figure 5: Identifying the filesharing site contacted by the infected machine

After filtering for the suspected IP address, I reviewed the host field in the returned HTTP events. The infected machine connected to pastebin.com, which was the filesharing site used for C2 communication.

Answer: pastebin.com

What is the full URL of the C2 to which the infected host is connected?

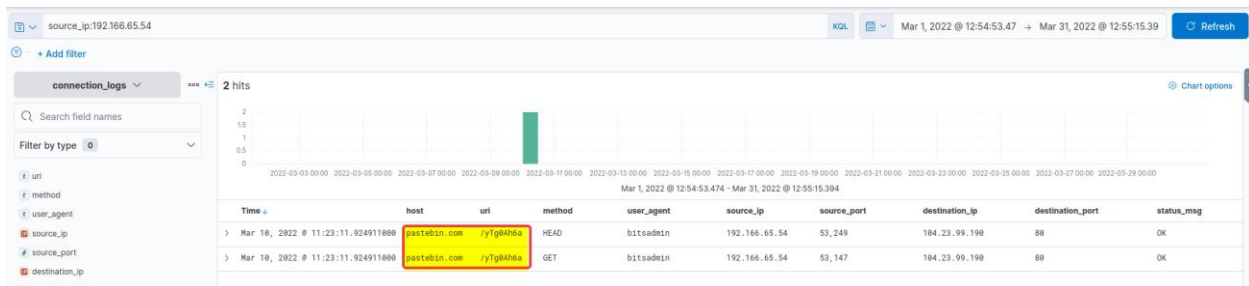


Figure 6: Identifying the full C2 URL from the host and URI fields

I reviewed the host and uri fields from the filtered events. The host was pastebin.com and the URI path was /yTg0Ah6a, giving the full C2 URL as http://pastebin.com/yTg0Ah6a.

Answer: pastebin.com/yTg0Ah6a

A file was accessed on the filesharing site. What is the name of the file accessed?

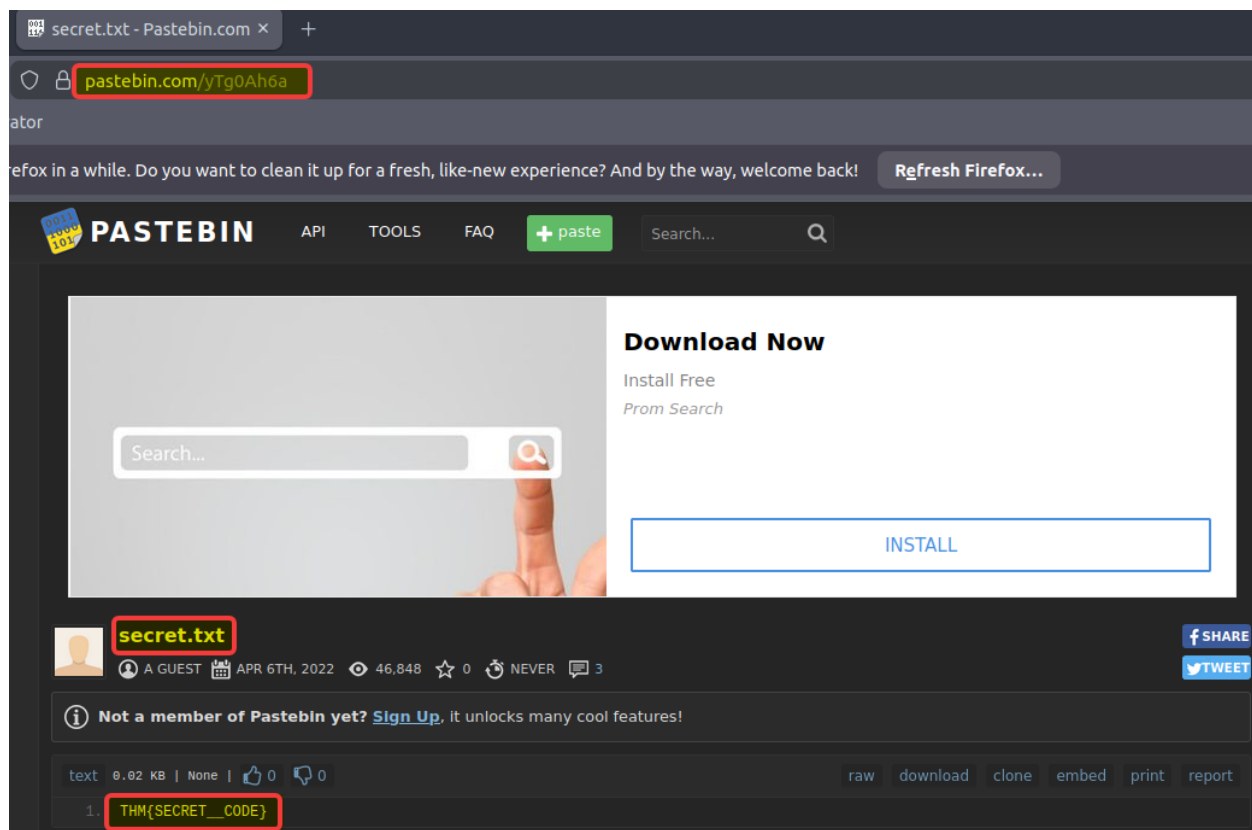


Figure 7: Visiting the Pastebin C2 URL and identifying the accessed file

After identifying the full Pastebin C2 URL from the logs, I visited the URL directly to inspect the hosted content. The Pastebin page showed the accessed file name as secret.txt.

Answer: secret.txt

The file contains a secret code with the format THM{_____}.

After opening the Pastebin page, I reviewed the content of secret.txt. The file contained the secret code THM{SECRET__CODE}.

Answer: THM{SECRET__CODE}